

Scheda di lettura - SRC-0037

Abualhaija et al. (2025) - LLM-assisted Extraction of Regulatory Requirements: A Case Study on the GDPR

Tipo	Ricerca primaria empirica; IEEE Requirements Engineering Conference 2025, pp. 142-154
DOI	10.1109/RE63999.2025.00023
Copia letta	Author postprint pubblico, 13 pagine
File locale	SRC-0037-abualhaija-ceci-sannier-et-al-2025.pdf
SHA-256	830db5c091015faffc280e4345dd859ec3937d023963dccf88e0c5c17cc082c6
Storage sorgente	Fuori dal repository Git

1. Problema e contributo

Il paper affronta il divario fra interpretazione legale e sviluppo software. Il GDPR formula diritti generali, ma i dettagli necessari per requisiti implementabili dipendono spesso da linee guida, giurisprudenza, letteratura e contesto applicativo.

- Costruisce con esperti un riferimento di **108 requisiti**: 61 per il diritto di accesso (ACC) e 47 per la portabilità (PRT).
- Mantiene trace link verso le fonti legali usate per ciascun requisito.
- Propone **XTRAREG**, una pipeline LLM + RAG per generare requisiti privacy candidati con riferimento e rationale.
- Valuta separatamente correttezza, coverage, groundedness e plausibilità.

La fonte non dimostra conformità automatica: dimostra assistenza alla costruzione di requisiti candidati che richiedono selezione delle fonti e revisione legale.

Requisito plausibile + citazione presente != obbligo completo, corretto e giuridicamente grounded.

2. Ruolo per DDTA

SRC-0037 fornisce evidenza diretta per il confine documentazione normativa -> requisito privacy candidato -> revisione esperta. Integra SRC-0035 e SRC-0036, mostrando che anche un output testuale apparentemente corretto può essere incompleto, duplicato o misgrounded.

fonti normative governate -> estrazione assistita -> candidato -> verifica di correttezza, coverage e grounding -> review legale -> requisito accettato

Riferimento umano e significato legale

3. Corpus e processo esperto

Sei subject-matter expert contribuiscono alla selezione, estrazione, consolidamento e raffinamento. Il paper non calcola inter-rater agreement per la fase di estrazione: i disaccordi vengono risolti in sessioni interattive.

Codice	Fonte	Uso
L	Legislazione	Obblighi minimi
J	Decisioni giudiziarie	Obblighi minimi e interpretazione autorevole
G	Linee guida o specifiche ufficiali	Dettagli e best practice
T	Letteratura giuridica	Interpretazioni e chiarimenti
E	Opinione di esperto legale	Interpretazione contestuale

4. Tre osservazioni giuridico-ingegneristiche

- **Best practice:** alcune prescrizioni non sono obblighi minimi, ma riducono il rischio di violazione e rendono più difendibile la conformità.
- **Dipendenza dal contesto:** norme generali possono restare vaghe finché non sono noti dominio, giurisdizione, settore, formato, canale e processo operativo.
- **Interpretazioni alternative:** più letture possono essere corrette; la scelta dipende da autorità della fonte e contesto, mentre le alternative devono restare tracciate.

5. Compliance scoring

Classe	Origine	Conseguenza
Minimal Compliance	Legislazione e decisioni giudiziarie	Mancata soddisfazione: red flag di non conformità
Recommended / Best Practice	Linee guida, letteratura, esperti	Mancata soddisfazione: warning e minore forza dell'argomento di conformità

Il paper collega il livello di confidenza nella conformità all'autorità della fonte. Questa classificazione è utile, ma non sostituisce l'analisi di applicabilità e il parere legale sul progetto concreto.

6. Esempio della Figura 1

Il solo Art. 20 GDPR produce un requisito generico di trasferimento. Le linee guida aggiungono quali dati includere, ad esempio dati osservati durante l'uso del servizio. La figura rende visibile la differenza fra norma generale e requisito operativo dettagliato.

norma generale != requisito direttamente implementabile

Pipeline XTRAREG e valutazione

7. Pipeline

esperto legale + requirements engineer -> fonti applicabili -> prompt ZSL/CoT -> RAG per singola fonte -> LLM -> parser -> liste concatenate di requisiti candidati

La selezione delle fonti è uno step manuale preliminare. Il RAG non decide quali fonti sono applicabili e non trasforma automaticamente il risultato in requisito accettato.

Elemento	Configurazione
Modelli	gpt-3.5-turbo-0125; gpt-4o-2024-08-06
Prompt	Zero-shot, Chain-of-Thought, variante ZSL-dagger senza RAG
Temperatura	0,3
Chunk	1000 caratteri, overlap 200
Retrieval	top-k 4, distanza euclidea
Embedding	text-embedding-ada-002, 1536 dimensioni
Vector store	Chroma tramite LangChain

8. Valutazione

- **Metriche automatiche:** BLEU, ROUGE-L, METEOR e BERTScore.
- **Correttezza esperta:** corretto, parzialmente corretto o errato; scala 1-5.
- **Groundedness:** grounded, incompleto, misgrounded o ungrounded.
- **Plausibilità:** il rationale supporta ragionevolmente il requisito.
- **Coverage:** mapping dei requisiti generati ai 108 requisiti di riferimento.

Le configurazioni con RAG sono eseguite due volte; l'ablation senza RAG dieci volte. Il confronto è utile ma non perfettamente simmetrico.

9. Perché le metriche automatiche non bastano

Il paper rifiuta l'uso del solo LLM-as-a-judge per rischio di self-enhancement bias e perché l'equivalenza giuridica richiede competenza legale. Inoltre, il massimo score contro il riferimento assume implicitamente una relazione uno-a-uno che può non valere.

similarità testuale o semantica != equivalenza normativa

Risultati empirici

10. GPT-4o + ZSL + RAG

Dimensione	ACC	PRT
Requisiti generati	22	14
Duplicati	8 (36,4%)	4 (28,6%)
Requisiti di riferimento identificati	16	8
Corretti + parziali	18/22 (81,8%)	12/14 (85,7%)
Pienamente corretti*	14/22 (63,6%)	5/14 (35,7%)
Grounded	15/22 (68,2%)	7/14 (50,0%)
Riferimenti incompleti	6/22 (27,3%)	3/14 (21,4%)
Misgrounded	1/22 (4,5%)	4/14 (28,6%)

* Calcolo del ricercatore dalla Tabella III; non è una metrica nominata dagli autori.

11. Coverage del corpus

Rispetto all'intero corpus umano, la copertura effettiva è:

ACC: 16/61 = 26,2% | PRT: 8/47 = 17,0%

Una quota elevata di output corretti o parzialmente corretti non implica che il sistema abbia trovato gli obblighi applicabili.

12. Effetto del RAG

- Migliora in generale metriche e numero di requisiti rispetto alle configurazioni senza RAG.
- Non guida efficacemente GPT-4o verso fonti oltre gli articoli GDPR direttamente associati al diritto.
- Produce duplicati perché i risultati ottenuti per fonti diverse vengono concatenati.
- Non garantisce riferimenti completi o corretti.

13. Errori qualitativi

- Prospettiva errata: descrizione del diritto anziché comportamento del sistema.
- Requisiti generici, eccezioni omesse e azioni scorrette.
- Testo legale copiato ma non trasformato in obbligo azionabile.
- Citazioni di considerando senza disposizioni normative sufficienti.

RAG presente != requisito grounded; requisito accettabile != coverage sufficiente.

Limiti, discrepanze e controlli DDTA

14. Limiti

- Due soli diritti GDPR e nessun progetto software concreto.
- Nessuna verifica dell'implementazione o della conformità reale.
- Valutazione giuridica soggettiva; mapping non necessariamente uno-a-uno.
- Copertura bassa, duplicati e riferimenti incompleti o misgrounded.
- Nessuna misura dell'effort di correzione o del tasso di requisiti finali accettati.
- Nessuna gestione di evoluzione normativa, applicabilità temporale o staleness.
- Modelli e API storici rispetto al 2026; comportamento e ranking non sono attuali.
- Annex e artefatto identificati ma non eseguiti indipendentemente.

15. Discrepanze da preservare

- Il PDF supporta 85,7% per PRT; alcuni metadati esterni riportano 56,7%.
- Accuracy aggrega requisiti corretti e parzialmente corretti.
- Coverage e usato sia rispetto agli output sia rispetto al corpus umano.
- La metodologia descrive un esperto per la valutazione estrinseca; le threats to validity parlano di due esperti.
- Il testo dice che RAG ha impatto significativo senza riportare un test statistico di significatività.
- La tassonomia usa T per letteratura, mentre il compliance scoring riporta D.
- La conclusione arrotonda ACC a 81%, contro 81,8% altrove.

16. Lifecycle DDTA candidato

fonti normative governate -> applicabilità e autorità -> segmenti con provenance -> requisito candidato -> deduplicazione -> verifica di prospettiva, azionabilità, correttezza, coverage e grounding -> alternative preservate -> review legale -> accepted | corrected | rejected | deferred -> stale dopo cambi normativi, contestuali, del modello, prompt o indice

17. Regole risultanti

- citazione presente != citazione valida
- rationale plausibile != requisito corretto
- requisito corretto != corpus completo
- norma generale != requisito implementabile
- RAG != assurance

Utilita limitata e compatibilita futura per threat-forge

Base del confronto: repository threat-forge, master al commit cae0f7b6b37f430ac4e857aabf6ef9f87c89dbb1.

18. Cosa conferma dell architettura attuale

Evidenza SRC-0037	Conseguenza limitata per threat-forge
L estrazione automatica e incompleta e fallibile.	Conferma il candidate-first boundary: nessun output assistito deve diventare conoscenza canonica senza review.
Ogni requisito dipende da fonti e segmenti verificabili.	Conferma provenance, source occurrence e review esplicita gia richieste dal modello documentale e dalla Base Analysis.
Applicabilita e dettagli dipendono dal contesto.	Conferma che eventuali future fonti legali dovrebbero essere project-local nel Target Project.
Correttezza, coverage e grounding divergono.	Suggerisce che una futura espansione non dovrebbe ridurre tutto a un solo stato valid/invalid.
Duplicati e interpretazioni alternative sono normali.	Conferma che merge, split e scelta fra alternative devono restare operazioni governate.

19. Decisione di scope per la tesi

La tesi e lo sviluppo parallelo **non introducono ora** un modulo di analisi normativa, un nuovo document model legale, un plugin regulatory, una pipeline RAG giuridica o una dichiarazione di conformita GDPR.

La fonte viene usata soltanto per evitare preclusioni architetturali: il modello documentale e la Base Analysis devono poter accogliere in futuro requisiti, fonti, dati, attori, componenti, flussi e decisioni provenienti da una revisione legale governata, senza incorporare oggi semantica giuridica nel core.

in scope: compatibilita futura e confini neutrali out of scope: estrazione legale, review workflow, compliance scoring e automazione normativa

20. Vincoli di compatibilita sufficienti

- Le fonti e la provenance restano rappresentabili senza assumere una tassonomia legale nel core.
- I requisiti accettati possono alimentare la documentazione di un Target Project come normali fonti governate.
- La Base Analysis resta methodology-neutral e puo rappresentare attori, dati, componenti, boundary e flussi emersi da future analisi legali.
- Lo stato candidato/accettato e la staleness restano estensibili senza automatizzare oggi la normativa.
- I plugin di threat analysis non vengono confusi con eventuali futuri estrattori normativi.

21. Relazione con Base Analysis e threat analysis

Un futuro requisito privacy accettato potrebbe rendere visibili data subject, controller, personal data, request channel, export service, identity verification, trasferimenti e boundary organizzativi. Questi elementi migliorerebbero il contesto del threat analysis, ma non sono essi stessi threat finding.

La scelta di scope e quindi conservativa: threat-forge rimane estensibile, ma la tesi non assume l onere di progettare o validare un sottosistema legale.

22. Stato della lettura

Testo	Completo, 13 pagine
Figure	2/2 verificate
Tabelle	3/3 verificate
Discrepanze	Registrate, incluso 56,7% vs 85,7%
Annex/tool	Identificati, non eseguiti
Scope threat-forge	Compatibilita futura soltanto; nessuna implementazione normativa nella tesi

ThreatForge mapping basis: MR-0003, MR-0004, MR-0005, MR-0003/ADR-0003, MR-0005/ADR-0002, MR-0005/ADR-0003 e MR-0001/ADR-0009.